UNIT 2 · TOPIC 2.1

Security Foundations: CIA Triad

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. Which of the following best describes a social engineering attack?

○ A. An adversary uses a port scanner to enumerate open services on a target server.

● B. An adversary sends a fraudulent email impersonating a bank to trick an employee into revealing login credentials.

○ C. An adversary intercepts encrypted network traffic between two hosts to capture session tokens.

○ D. An adversary exploits a buffer overflow in a web application to execute arbitrary code.

Correct answer: B

Why: Social engineering attacks manipulate human behavior rather than exploiting technical vulnerabilities. Sending a fraudulent email that impersonates a trusted institution to obtain credentials (phishing) is the defining example of social engineering. The other options all describe technical attacks: port scanning (A) is network reconnaissance, traffic interception (C) is a network-layer attack, and buffer overflow exploitation (D) targets a software vulnerability, none of these rely on deceiving a human.

*Why the others are wrong: **A**, Plausible because port scanning is often taught alongside attack methods, but it is reconnaissance, not manipulation of a person. **C**, Plausible because credential theft can result from both social engineering and network interception; students may conflate the outcome with the method. **D**, Plausible because software exploits are the most prominent attack type students encounter first; they may misclassify any credential compromise as social engineering.*

2. An organization's intellectual property is exfiltrated after a prolonged, covert intrusion traced to a foreign government agency. Which type of adversary best characterizes this threat actor?

● A. Nation-state actor

○ B. Insider threat

○ C. Script kiddie

○ D. Hacktivist

Correct answer: A

Why: Nation-state actors are government-sponsored threat actors who conduct sophisticated, long-duration campaigns targeting strategic assets such as intellectual property, critical infrastructure, and national security information. The indicators here, foreign government attribution, covert persistence, and IP theft, all match the nation-state profile.
Script kiddies (C) lack sophistication and are not government-affiliated. Insider threats (B) originate from within the organization. Hacktivists (D) are motivated by ideology, not strategic espionage.

*Why the others are wrong: **B**, Plausible because insider threats also have prolonged access; students may overlook the "foreign government" indicator. **C**, Plausible to newer students who assume all attacks are simple; the "foreign" element should distinguish this from script kiddies. **D**, Plausible because hacktivists are a memorable adversary type; students may not recall that their motive is public protest, not espionage.*

3. During which phase of a cyberattack does an adversary collect information about a target organization, such as employee email formats, public IP ranges, and exposed services?

● A. Reconnaissance

○ B. Lateral movement

○ C. Exploitation

○ D. Exfiltration

Correct answer: A

Why: Reconnaissance is the initial phase in which the adversary gathers intelligence about the target before launching an active attack. This includes passive OSINT gathering and active techniques such as port scanning. Exploitation (C) occurs when the adversary actively leverages a discovered vulnerability, it requires information gathered during reconnaissance. Lateral movement (B) assumes the adversary is already inside the network. Exfiltration (D) is a late-stage action that removes data after access has been achieved.

*Why the others are wrong: **B**, Plausible if students know lateral movement involves discovery of internal systems; they may confuse internal enumeration with initial reconnaissance. **C**, Plausible because port scanning "does something" to the target; students may conflate active reconnaissance with exploitation. **D**, Plausible if students focus on the outcome (stolen data) rather than the phase being described (collection of target information before the attack).*

4. An adversary researches a target company's social media to identify employee names and job roles, then builds a custom malicious email attachment tailored to the company's HR department. Which two consecutive phases of the cyberattack lifecycle are represented, in order?

○ A. Exploitation → Lateral movement

● **B. Reconnaissance → Weaponization**

○ C. Weaponization → Delivery

○ D. Delivery → Exploitation

Correct answer: B

Why: Researching social media to identify targets is reconnaissance, the information-gathering phase. Building a customized malicious attachment based on that research is weaponization, the phase in which the adversary constructs the attack tool. These two phases are consecutive and causally linked: the adversary cannot tailor the weapon without first completing reconnaissance. Exploitation (A) and lateral movement occur later, after the weapon is delivered and executed. Delivery (C, D) is the next phase after weaponization, not what is described here.

*Why the others are wrong: **A**, Plausible if students conflate "researching the target" with "exploiting" it; the confusion arises from the word "targeting." **C**, Plausible because weaponization is correctly identified, but students may rush to delivery without recognizing that reconnaissance precedes it. **D**, Plausible for students who know the attack sequence but anchor to "building the attachment" as delivery rather than weaponization.*

5. A security team discovers that a customer database server is running an unpatched version of its database software, and that adversaries are actively exploiting that exact vulnerability in similar organizations. A breach would expose 200,000 customer records and trigger regulatory fines. After identifying these facts, what is the most appropriate next step in the risk assessment process?

○ A. Immediately apply the available patch to eliminate the vulnerability before completing the assessment.

○ B. Notify law enforcement of the ongoing threat campaign affecting the industry.

● **C. Document the likelihood and impact of exploitation to produce a risk rating for this asset.**

○ D. Transfer the risk by purchasing a cyber liability insurance policy.

Correct answer: C

Why: Risk assessment is a structured process: identify assets, identify threats and vulnerabilities, then calculate risk as a function of likelihood and impact. The team has already identified the asset (database server), the vulnerability (unpatched software), and the threat (active exploitation in the wild). The next step is to produce a documented risk rating, quantifying likelihood (high, given active exploitation) and impact (high, given regulatory exposure and record count). Patching (A) is a risk response action that follows the assessment. Notifying law enforcement (B) and transferring risk (D) are also post-assessment decisions.

*Why the others are wrong: **A**, Very plausible, patching feels like the obvious right action; students may not recognise that a formal risk rating must precede and justify the response decision. **B**, Plausible because threat intelligence sharing is a real practice; students may conflate information sharing with risk assessment steps. **D**, Plausible because risk transfer is a legitimate strategy; students who remember the strategies may apply one prematurely before the assessment is complete.*

6. An employee reuses their work email password on a personal shopping website. The shopping site is breached and plaintext passwords are leaked publicly. Which statement best explains how password reuse converts a personal breach into organizational cybersecurity risk?

○ A. The leaked shopping site password becomes a new threat that directly attacks the organization's firewall.

● B. Password reuse creates a vulnerability in the employee's work account that a threat actor can exploit using the leaked credential, generating risk to organizational assets.

○ C. The breach reduces risk to the organization because the adversary already has what they want from the shopping site.

○ D. Password reuse is a threat, not a vulnerability, because it is an action taken by the employee rather than a weakness in a system.

Correct answer: B

Why: Risk arises when a threat exploits a vulnerability to affect an asset. Password reuse is a vulnerability, a weakness in the employee's security posture. The leaked credential in adversary hands constitutes a threat that can be used to exploit that vulnerability, granting unauthorized access to organizational assets (the employee's work account and any systems accessible from it). Option A incorrectly calls the password a "threat" and misidentifies the target. Option C misapplies the risk model, adversary satisfaction from one breach does not reduce the credential's value for follow-on attacks. Option D conflates actions with threat/vulnerability classifications; vulnerability refers to weakness, regardless of whether it is human-originated.

*Why the others are wrong: **A**, Plausible because students may think "leaked password → attack on organization" and mentally shortcut to "the password is the threat." **C**, Plausible to students who reason informally about adversary motivation without applying the formal risk model. **D**, Plausible because the distinction between threat and vulnerability is subtle; employee behavior feels more like an "action by someone" (threat) than a "weakness" (vulnerability).*

7. A NIST risk assessment of a regional hospital finds: (1) adversaries actively and frequently target healthcare organizations; (2) the hospital's electronic health record (EHR) system has not received a security patch in 18 months; (3) a confirmed breach would trigger HIPAA penalties, patient harm lawsuits, and reputational loss. Which evaluation of this risk is most consistent with NIST risk assessment methodology?

○ A. Low priority, the EHR system is behind the hospital's perimeter firewall, reducing exposure.

○ B. Moderate priority, the threat is real but likelihood is reduced because healthcare breaches are usually opportunistic, not targeted.

● C. High priority, high threat frequency combined with a known unpatched vulnerability and severe multi-dimensional impact places this risk in the highest tier.

○ D. Indeterminate, a risk rating cannot be assigned without first completing a full asset inventory.

Correct answer: C

Why: NIST risk methodology evaluates risk as a function of threat likelihood and impact. Here, likelihood is high: healthcare is a high-frequency target sector and the specific vulnerability (18-month patch gap) is known to adversaries who scan for exactly these exposures. Impact is also high: HIPAA penalties, civil liability, and reputational damage are all severe and multi-dimensional. Both factors at high levels produce a highest-tier risk rating. Option A incorrectly assumes a perimeter firewall is sufficient mitigation, it addresses network exposure but not unpatched software reachable through allowed traffic.

Option B mischaracterizes healthcare threat actors; healthcare is a persistently targeted

sector. Option D misapplies the process, sufficient asset context is already present to assign a risk rating.

*Why the others are wrong: **A**, Plausible, students who learned perimeter defense as the primary control may over-rely on it; they may not yet apply layered analysis. **B**, Plausible because students may confuse "opportunistic" with "low likelihood" without recognizing that healthcare's data value makes it a deliberate target. **D**, Plausible for process-focused students who know NIST requires an asset inventory step and apply it too rigidly, overlooking that sufficient information already exists.*

8. An organization relies solely on a perimeter firewall for network protection. An adversary bypasses it by convincing an employee to click a malicious link in a spear-phishing email, installing a remote access tool on the employee's workstation. The adversary then moves freely through the internal network for three weeks undetected. Which fundamental weakness of a single-control strategy does this scenario most precisely expose?

○ A. Perimeter firewalls cannot inspect HTTPS traffic, making all encrypted attacks undetectable.

○ B. User awareness training is always more effective than technical controls at preventing phishing.

● C. A single control layer, when bypassed through an alternative attack vector, leaves no remaining detection or containment capability.

○ D. Remote access tools are always classified as malware and should be blocked at the firewall by default.

Correct answer: C

Why: The scenario illustrates the core argument for defense in depth: no single control can intercept every attack vector. The perimeter firewall was not designed to inspect employee behavior or endpoint activity, so an attack delivered via social engineering bypassed it entirely. With no additional controls, no email filtering, no endpoint detection, no network segmentation, no behavioral monitoring, the adversary operated undetected for weeks. A layered strategy places controls at multiple points so that bypassing one layer does not grant unrestricted access. Option A describes a real limitation but is not the primary lesson of the scenario. Option B is an overstatement that incorrectly dismisses technical controls. Option D misrepresents how firewalls work with legitimate remote access tools.

*Why the others are wrong: **A**, Plausible and technically accurate in some configurations; students with networking background may focus on this specific firewall limitation rather than the structural single-point-of-failure argument. **B**, Plausible because training is often presented as the answer to phishing; students may conclude training alone would have prevented this attack. **D**, Plausible if students overapply the rule about malicious software without recognizing that remote access tools have legitimate uses and are not blocked by default.*

9. A threat intelligence report describes a hacktivist group targeting energy companies: they first conduct open-source reconnaissance to identify exposed industrial control systems (ICS), then launch DDoS attacks to disrupt operations. An analyst must brief leadership on the risk. Which analysis is most accurate and complete?

○ A. The group represents a low-sophistication threat because DDoS tools are widely available and require minimal technical skill.

○ B. The group is likely a nation-state actor using hacktivist branding, because the two-phase approach indicates advanced persistent threat (APT) characteristics.

● C. The reconnaissance phase meaningfully increases attack effectiveness by enabling the adversary to target specific ICS exposure points rather than launching undifferentiated attacks.

○ D. The group's primary motivation is financial gain, consistent with typical hacktivist objectives.

Correct answer: C

Why: Reconnaissance serves a precise strategic function: it reduces the adversary's uncertainty about which specific assets are vulnerable, enabling targeted rather than generic attacks. Against ICS, which controls physical infrastructure, targeted disruption is far more damaging than a broad, undifferentiated DDoS. This is the most accurate and actionable analytical insight for leadership. Option A conflates tool availability with threat severity;

a DDoS against a power grid's ICS carries high impact regardless of the tool's availability. Option B incorrectly classifies the adversary; the defining features of APTs are nation-state sponsorship and long-term persistence for espionage, not ideologically motivated disruption. Option D misidentifies hacktivist motivation; hacktivists are driven by ideology and public protest, not financial gain (which characterizes cybercriminals).

*Why the others are wrong: **A**, Plausible because DDoS is commonly taught as a "basic" attack; students may not apply impact-based risk reasoning to a critical infrastructure context. **B**, Plausible because multi-phase attacks remind students of APT kill chains; distinguishing adversary motivation (ideology vs. espionage) requires careful recall. **D**, Plausible because cybercrime is the dominant adversary motivation students encounter; hacktivism is a separate category they may confuse with financially motivated groups.*

10. Which of the following is an example of a technical security control?

○ A. Requiring all employees to complete annual cybersecurity awareness training.

● **B. Deploying an intrusion detection system (IDS) to monitor network traffic for malicious activity.**

○ C. Issuing a written policy prohibiting the use of personal devices on the corporate network.

○ D. Conducting background checks on new employees before granting system access.

Correct answer: B

Why: Technical controls are implemented through hardware or software to enforce security policy automatically. An intrusion detection system monitors network traffic and generates alerts without requiring human intervention for each event, it is a technology-based control. Annual training (A) and background checks (D) are administrative controls, procedural measures that rely on human processes. A written policy (C) is also an administrative control; enforcement mechanisms would be technical, but the policy itself is not.

*Why the others are wrong: **A**, Plausible because training is taught alongside controls; students may not yet have internalized the technical vs. administrative distinction. **C**, Plausible because policies are foundational to security programs; students may confuse a policy (administrative) with the system that enforces it (technical). **D**, Plausible because background checks feel like a formal, rigorous process, students may categorize "formal" with "technical."*

11. An organization determines that a specific vulnerability has a very low probability of exploitation and that the cost of mitigation significantly exceeds any potential loss. Which risk management strategy is most appropriate?

○ A. Risk avoidance

○ B. Risk transfer

● **C. Risk acceptance**

○ D. Risk reduction

Correct answer: C

Why: Risk acceptance is the strategy of knowingly tolerating a risk because the cost of addressing it outweighs the potential harm. When both likelihood and impact are low and mitigation costs are high, accepting the residual risk is the rational business decision, with the expectation that the risk will be monitored for changes. Risk avoidance (A) eliminates the activity that creates the risk. Risk transfer (B) shifts financial consequences to a third party, such as through insurance. Risk reduction (D) deploys controls to decrease likelihood or impact, appropriate when the risk justifies the cost.

*Why the others are wrong: **A**, Plausible because "avoiding" a risk sounds like doing nothing; students may conflate acceptance with avoidance. **B**, Plausible because insurance is a common real-world response to risk; students may default to transfer without evaluating cost vs. impact. **D**, Plausible because risk reduction sounds like the "responsible" answer; students may choose it without checking whether cost justifies deployment of a control.*

12. A company installs security cameras at all building entrances, requires an access badge to enter server rooms, and uses a man-trap at the data center door. These are all examples of which control category?

○ A. Technical controls

○ B. Administrative controls

● **C. Physical controls**

○ D. Operational controls

Correct answer: C

Why: Physical security controls protect the physical environment in which information systems operate. Security cameras, badge-access systems, and man-traps all restrict or monitor physical access to facilities and hardware, they do not operate at the software or network layer. Technical controls (A) use hardware or software to enforce security policy (e.g., firewalls, encryption). Administrative controls (B) are policy- and procedure-based (e.g., acceptable use policies, training requirements). Operational controls (D) are day-to-day security practices, which overlap significantly with administrative controls.

*Why the others are wrong: **A**, Plausible because badge readers and cameras involve technology; students may focus on the hardware component rather than the physical-access protection function. **B**, Plausible because access policies govern who may enter a room; students may confuse the policy (administrative) with its physical enforcement mechanism. **D**, Plausible because "operational" sounds like physical operations; students may not have a clear distinction between operational and physical in their mental model.*

13. An organization implements multi-factor authentication (MFA) for all remote access connections. Which statement best explains how MFA mitigates the risk of unauthorized access through compromised credentials?

○ A. MFA prevents adversaries from discovering employee usernames through open-source reconnaissance.

○ B. MFA eliminates the risk of credential-based attacks by replacing passwords with biometric authentication entirely.

● **C. MFA makes a stolen or guessed password alone insufficient to authenticate, because a second independent factor is also required.**

○ D. MFA detects and blocks brute-force login attempts in real time.

Correct answer: C

Why: MFA mitigates credential theft risk by adding an authentication factor, typically something the user possesses (a phone or hardware token) or a biometric, to the knowledge factor (password). Even if an adversary obtains the password through phishing or a data breach, they cannot authenticate without the second factor. This is the control's core risk-mitigation mechanism. MFA does not prevent reconnaissance of usernames (A), that is a separate attack surface. MFA does not eliminate passwords universally (B); most MFA implementations add to, rather than replace, passwords. Rate limiting and lockout policies detect brute-force attempts (D), not MFA itself.

*Why the others are wrong: **A**, Plausible because students know MFA improves security holistically; they may overgeneralize its protection to include the reconnaissance phase. **B**, Plausible because biometric MFA is a well-known form; students may assume biometric MFA means passwords are fully replaced, which misrepresents most implementations. **D**, Plausible because MFA is often discussed alongside account lockout policies; students may conflate two separate controls that are often deployed together.*

14. A security team deploys email filtering to block phishing messages, endpoint protection software on all user devices, and network segmentation to isolate critical servers from the general office network. Which security strategy do these three controls together illustrate?

○ A. Principle of least privilege

○ B. Security through obscurity

● **C. Defense in depth**

○ D. Zero-trust architecture

Correct answer: C

Why: Defense in depth is the strategy of deploying multiple independent security controls across different layers, communication, endpoint, and network, so that an attack bypassing one layer encounters additional barriers at the next. Email filtering addresses the delivery vector, endpoint protection addresses execution, and segmentation limits blast radius if both prior controls fail. Together they form overlapping protective layers. Least privilege (A) governs access rights, not layered control deployment. Security through obscurity (B) relies on hiding system details, it is widely considered insufficient as a primary strategy. Zero trust (D) is a related model centered on continuous identity verification; it is not the concept illustrated by these three specific control types.

*Why the others are wrong: **A**, Plausible because least privilege is a foundational principle taught alongside defense in depth; students may apply the wrong principle to a layered control scenario. **B**, Plausible if students misremember "obscurity" as a general term for "layering hidden defenses"; the conceptual distinction between obscurity and depth is often blurred. **D**, Plausible because zero trust is a current, widely publicized strategy; students may label any multi-control deployment as zero trust without understanding its specific identity-centric definition.*

15. A company's web application is built on a framework that is no longer supported and cannot be patched. Leadership proposes three responses: (1) migrate the application to a supported framework; (2) purchase cyber liability insurance; (3) decommission the application permanently. Which risk management strategies do options 1, 2, and 3 represent, respectively?

○ A. Risk acceptance, risk reduction, risk avoidance

○ B. Risk avoidance, risk reduction, risk transfer

○ C. Risk transfer, risk acceptance, risk reduction

● D. Risk reduction, risk transfer, risk avoidance

Correct answer: D

Why: Migrating to a supported framework eliminates the underlying vulnerability, thereby reducing the likelihood of exploitation, this is risk reduction. Purchasing cyber liability insurance does not change the vulnerability; it shifts the financial consequences of a breach to the insurer, this is risk transfer. Decommissioning the application removes the activity that creates the risk entirely, this is risk avoidance. Risk acceptance (knowingly tolerating the risk with no response) is not represented among the three options proposed, which is itself a signal that leadership is treating this as a high-priority risk.

*Why the others are wrong: **A**, Plausible because students may confuse migration (an active remediation) with acceptance, perhaps thinking that keeping the app running in any form is "accepting" the risk. **B**, Plausible if students reason that "decommissioning = avoiding the issue" comes first, before any other action, applying avoidance to the migration option instead. **C**, Plausible if students swap insurance and migration; both involve ongoing commitment of resources, making them easy to mis-sequence.*

16. A NIST security audit of an organization reveals: the perimeter firewall's access control lists are excessively permissive; endpoint antivirus signature databases are six months out of date; no network segmentation exists between the corporate LAN and production servers; and security awareness training is conducted once every two years. Which assessment of the organization's defense-in-depth posture is most accurate?

● A. Controls exist at multiple layers but each is severely degraded, creating exploitable gaps that an adversary could chain together to achieve full network compromise.

○ B. The outdated antivirus is the sole critical weakness; the remaining controls are functioning adequately.

○ C. Network segmentation is unnecessary given that a perimeter firewall already restricts external traffic.

○ D. The organization has a sound defense-in-depth strategy because controls are present at all four layers.

Correct answer: A

Why: Defense in depth requires that controls at each layer be operationally effective, not merely present. A permissive firewall fails to enforce access policy, outdated signatures

allow modern malware to execute undetected, a flat network architecture allows unrestricted lateral movement after initial compromise, and infrequent training leaves users susceptible to phishing. An adversary can chain these gaps: exploit the permissive firewall rule to reach a vulnerable endpoint, deploy malware the antivirus will not detect, and move laterally to production servers without hitting a segmentation boundary. Presence is necessary but not sufficient, effectiveness determines actual security posture. Option D conflates presence with effectiveness. Option B isolates one weakness arbitrarily; all four controls are degraded. Option C contradicts the core rationale for segmentation: internal lateral movement cannot be restricted by a perimeter firewall.

*Why the others are wrong: **B**, Plausible because antivirus is a highly visible, concrete control; students may anchor on the most obvious degraded control and overlook the systemic problem. **C**, Plausible because students who have studied perimeter defense may reason that external threats are the only relevant source; they may not yet apply inside-the-perimeter threat modeling. **D**, Highly plausible, students may check the control categories (firewall ✓, AV ✓, training ✓) and conclude the strategy is sound without evaluating operational effectiveness.*

17. A risk assessment identifies that an organization's primary threat is credential theft via phishing enabling access to cloud-hosted business applications. The team proposes four controls: (1) MFA on all cloud applications; (2) email filtering with malicious-link sandboxing; (3) physical access locks on the on-premises server room; (4) annual security awareness training. Which combination most directly addresses the identified threat model, and why is the excluded control less relevant?

○ A. Controls 2, 3, and 4; MFA (1) does not prevent the initial phishing delivery that enables credential theft.

● B. Controls 1, 2, and 4; physical access locks (3) do not address a credential-based attack targeting cloud applications.

○ C. Controls 1 and 3 only; training and email filtering introduce human error into the control chain.

○ D. All four controls equally address the identified threat because any security control improves overall posture.

Correct answer: B

Why: The threat model specifies phishing as the attack vector and cloud application access as the target. MFA (1) prevents stolen credentials from granting cloud access. Email filtering with sandboxing (2) reduces the likelihood that phishing emails reach users and can detonate malicious payloads in a safe environment. Security awareness training (4) reduces the probability that users act on phishing that does reach them. Together these three controls address delivery, credential use, and user behavior, all directly relevant. Physical access locks (3) protect on-premises hardware; they provide no protection against cloud-targeted credential attacks conducted entirely over the internet. Option A is incorrect: MFA is the most critical post-compromise control in a credential-theft scenario. Option C incorrectly dismisses two high-value controls. Option D violates the principle that control selection should match the threat model.

*Why the others are wrong: **A**, Plausible because MFA does not prevent phishing itself, only its downstream consequence, students may reason that MFA comes "too late" in the attack chain without recognizing it blocks the ultimate objective. **C**, Plausible for students who have encountered critiques of user-dependent controls (training and filtering rely on human behavior or signature accuracy); they may over-correct by excluding these. **D**, Plausible as a surface-level "more security is better" heuristic; students without a threat-modeling framework may not yet apply relevance filtering to control selection.*

18. A NIST risk assessment of a mid-sized financial organization identifies three active vulnerabilities: employees are susceptible to spear-phishing (social engineering vector); the internal network is flat with no segmentation between workstations and core financial systems (network vector); and critical servers are six months behind on patches (software vulnerability vector). The security team has budget to implement exactly two new controls this quarter. Which combination best applies defense-in-depth principles to the highest-impact vulnerabilities?

○ A. Deploy a new perimeter firewall and install physical security cameras at all building entrances.

○ B. Commission a full penetration test and hire one additional security analyst.

● C. Implement email filtering with integrated user awareness training, and deploy network segmentation between workstations and financial systems.

○ D. Enable full-disk encryption on all employee laptops and require badge access to the server room.

Correct answer: C

Why: Defense in depth requires that controls directly address the identified vulnerabilities at the highest-impact layers. Email filtering with awareness training targets the social engineering vector, the most common initial access path in financial sector attacks, by reducing both delivery success (filtering) and user susceptibility (training). Network segmentation between workstations and core financial systems eliminates the flat-network vulnerability, containing any breach that achieves initial access and blocking lateral movement to high-value targets. Together these two controls address two of the three identified vectors and reinforce each other: even if phishing succeeds (vector 1 partially bypassed), segmentation limits the attacker's reach (vector 2 controlled). Option A introduces a perimeter control and a physical control, neither directly addresses the three internal-facing vulnerabilities identified. Option B provides visibility and staffing but deploys no mitigating controls this quarter. Option D addresses data confidentiality and physical access, real controls, but not matched to the identified spear-phishing, flat-network, or patch-management vulnerabilities.

*Why the others are wrong: **A**, Plausible because a firewall upgrade sounds like a security improvement; students may not recognize that a perimeter control does not address internal lateral movement or phishing. **B**, Plausible because penetration testing is often discussed as best practice; students may reason that "finding problems" is equivalent to "fixing problems." **D**, Plausible because encryption and physical access are recognizable security controls; students may select them without checking whether they address the three specific identified vulnerabilities.*